

Contexto y Problema

Ecosistema Pallets-eco (Flask, Jinja2, MarkupSafe, etc) - 30 repositorios analizados.

Problema: Los ecosistemas de código abierto sufren vulnerabilidades en su código fuente y riesgos de cadena de suministros en sus dependencias.

Objetivo: Automatizar la minería, análisis estático (CodeQL) y escaneo de vulnerabilidades (Syft y Gripe) para priorizar riesgos en los proyectos de Pallets.

Arquitectura y flujo de trabajo

Miner: Clona repositorios de GitHub, genera SBOMs con Syft, ejecuta análisis CodeQL y Gripe

Analyzer: reportes JSON en un dataset unificado (dataset.csv) y procesa métricas con Jupyter/Pandas

Visualizer: Dashboard desarrollado en Dash/Plotly para explorar gráficos de vulnerabilidades y filtros dinámicos.

Reporter: reportes consolidados e inspector con cliente LLM

Calidad del software

Entorno Aislado: Ejecución bajo Docker / Dev Containers

Verificación de Herramientas: sincronización estricta de versiones (CodeQL 2.26.4, Syft 1.52.0, Gripe 0.120.0)

Testing: Suite automatizada de 174 tests unitarios e integración pasados al 100% (pytest).

Métricas Globales de Seguridad

Hallazgos Totales: 386 vulnerabilidades en 30 repositorios

CodeQL: 62 alertas en los 30 repositorios

Gripe: 324 vulnerabilidades en dependencias (13 repositorios)



pallets-eco

Desglose de Severidad de Vulnerabilidades

- Críticas 6
- Altas 138
- Medias 155
- Bajas 25

El 37% de las vulnerabilidades halladas corresponden a Niveles Alto o Crítico.

Análisis cualitativo de Riesgo

Reglas CodeQL más frecuentes: Alertas sobre prácticas de código no seguro, manejo inadecuado de excepciones o configuraciones débiles.

Paquetes Gripe más afectados: repositorios principales como flask o werkzeug concentran la mayor densidad de riesgo por volumen de dependencias directas.

Conclusiones

Aporte: La integración continua de SBOMs + SAST permite visibilidad total de la postura de seguridad de un ecosistema en tiempo real.

Recomendación: Priorizar la actualización de paquetes con severidad Crítica/Alta y corregir patrones recurrentes en CodeQL.